

第 6 章 操作系统安全（第二次作业及答案）

一、填空题

- 1、TCSEC（橘皮书）标准中，操作系统的安全级别从高到低分为：A1 级、B3 级、B2 级、B1 级、C2 级、C1 级 和 D 级。
- 2、安全访问令牌分为：主令牌 和 模拟令牌。
- 3、在 Windows 系统中，访问控制列表可以分为 自主访问控制列表 和 系统访问控制列表 两类。

二、选择题

- 1、windows7 操作系统访问控制策略包括（ ABC ）
A. 自主访问控制策略；
B. 基于角色的访问控制策略
C. 强制访问控制策略；
D. 基于属性的访问控制策略。
- 2、安全访问令牌在以下哪个模块中产生（ A ）
A. 本地安全认证（LSA）模块；
B. 安全账户管理（SAM）模块；
C. Netlogon 模块；
D. 安全引用监控器（SRM）模块。
- 3、安全访问令牌可以与以下哪些实体关联（ABD ）
A、进程； B. 用户； C. 资源； D. 线程； E. 被访问对象
- 4、Linux 系统的用户口令保存在以下文件中（ B ）
A. passwd 文件； B.shadow 文件； C.useradd 文件； D. group 文件
- 5、Linux 系统中，以下哪些设备采用块设备文件（ AB ）
A.U 盘； B 硬盘； C.打印机； D.传真

三、简答题

- 1、安全审计时，不仅要记录失败事件，还要记录成功事件，为什么？
答：
(1) 记录失败事件可以查看哪些操作失败了，从而分析失败的原因；
(2) 记录成功实践是因为，攻击者通过非法手段获得访问权限后，也会产生安全事件，通过记录成功实践可以进行事件溯源。
2. 简述 Android 和 Linux 操作系统安全机制之间的异同。

答:

Android 平台的基础是 Linux 内核, 因此 Android 的安全机制也是建立在 Linux 内核的安全基础之上的, 它为 Android 系统提供了 4 个方面的安全支持: 基于用户权限的安全模型, 进程隔离, 提供安全 IPC 的扩展接口, 移除内核中没有必要或有安全隐患的部分。Android 系统在继承 Linux 安全机制的同时, 也要考虑其移动平台的特殊性, 结合应用需求, Android 系统主要在以下几个方面提高系统的安全性

(1) Android 继承和扩展了 Linux 内核安全模型的用户与权限机制。在每个应用程序安装阶段, 赋予一个独立的 UID, 通常称为 app ID。应用执行时, 就在特定进程内以该 UID 运行。同时, 无论该进程是在原生还是在虚拟机内执行, 每个应用都有一个只有它才有读写权限的专用数据目录, 由此建立了内核级的应用沙盒。在 Linux 内核之上的程序库、虚拟机、系统服务和应用都可以运行在沙盒内。在一些操作系统中内存损坏是严重的安全隐患, 但在 Android 系统中由于应用的隔离, 内存的损坏只影响其对应的程序, 其他程序不受影响;

(2) 由于 Android 应用是沙盒隔离的, 它们只能访问自己的文件和一些设备上可全局访问的资源, 但这将限制 Android 的应用, 为此, Android 通过 AndroidManifest.xml 文件可以赋予应用额外的、细粒度的权限, 从而控制硬件设备、网络连接、数据或系统服务的访问;

(3) IPC Android 使用内核驱动和用户空间层的组合来实现 IPC 机制, 称为 Binder 机制。与 Linux 类似, Android 进程的地址空间是独立的, 一个进程不能直接访问另一个进程的内存空间, 即进程隔离。这种机制给系统带来稳定性和安全性的同时, 也阻隔了一个进程为另一个进程提供服务, 因此, Android 系统需要 IPC 机制帮助进程能够发现为其提供的服务并与之交互的进程。与 Windows 的 COM 和 Linux 的 CORBA 类似, Android 系统也采用一个基于抽象接口的分布式组件架构——Binder, 但与前者不同的是, Binder 机制更加灵活, 可靠性更高。它运行在单个设备上, 不支持 RPC 网络远程调用;

(4) 传统的 Android 安全模型严重依赖于应用的 PID, 虽然这是由内核提供的功能, 并且每个应用的文件都是私有的, 但无法完全禁止应用自身将它的文件改成全局可访问的文件。同理, 也无法禁止恶意应用程序利用系统文件或原生套接字过于宽松的访问标志位进行攻击。为此, Android 沿用了 Linux 安全增强技术 SELinux。

四、问答题

1、POSIX 是 IEEE 为 Linux 定制的可移植操作系统接口, 请简述 POSIX 的权能机制。

答:

(1) POSIX 权能机制是一种基于权能的最小特权控制机制, 其目的是实现比超级用户模式更细粒度的授权控制。它将特权划分成了一个权能集合;

(2) POSIX 权能机制提供了更为便利的权能管理和控制：一是提供了为系统进程指派一个权能去调用或执行受限系统服务的便捷方法；二是提供了一种使进程只能调用其执行特定任务必须权能的限制方法，支持最小特权安全策略的实现；

(3) POSIX 权能机制通过进程和程序文件权能状态(许可集、可继承集、有效权能集)，明确定义了进程如何获取和改变权能的语义，从而提供了一种基于进程所运行上下文控制进程权能的方法。

2、如何保护文件加密密钥（FEK）？一旦用户删除或系统重装，Windows 操作系统中的加密文件还能够恢复吗？

答：

(1) FEK 被用户数字证书公钥加密保护，还原 FEK 需要能够访问用户文件的加密证书私钥，这一私钥又得到用户主密钥的宝库，用户主密钥在用户口令的保护之下；

(2) 由于重置用户密码会失去原先的主密钥，从而失去访问 EFS 的访问能力，所以会导致不再能够打开原先使用 EFS 加密文件；

(3) 这种情况下，唯一的途径是在第一次加密文件时，备份 EFS 文件加密证书私钥。